

CO1 - AT3

ASSESSMENT TOOL - 3

- K. Nithin Varma

- 192312272

- ITA1405

- Ethical Hacking

C01 - ATJ - Assignment

22. You are asked to test the security awareness of employees by sending a phishing email that impersonates a company layoff announcement, since it's proven to get high click rates. Discuss the ethical boundaries of social engineering tests and psychological impact on staff.

A) Introduction :-

→ Social engineering tests are used by organizations to measure employee's awareness of cyber threats such as phishing. These tests should improve security awareness without causing unnecessary fear or emotional harm.

1. ETHICAL BOUNDARIES :

- Authorization : The test must be approved by management and follow company policies.
- Legitimate Purpose : The goal should be to improve cybersecurity awareness, not to embarrass or punish employee.
- Protect Privacy : Employee information collected during the test must remain confidential.

- No Public shaming : Employees who fail the test should receive private feedback instead of being publicly criticized.
- Debriefing : After the exercise, explain that it was a simulation and provide training on identifying Phishing attacks.

2) Psychological Impact on Staff :

- Employees may experience stress, anxiety or fear, especially if the phishing email mentions layoffs.
- Some employees may lose trust in management if they feel they were intentionally deceived.
- Repeated or harsh simulations can reduce morale and job satisfaction.
- Employees who fail may feel embarrassed or guilty, affecting their confidence.
- Well-designed and ethical tests can improve security awareness, confidence and preparedness against real cyber attacks.

3) BEST PRACTICES :

- * use realistic but non-traumatic phishing scenarios
- * Inform employees that security awareness exercises may occur
- * Provide immediate feedback and educational material after the test
- * Focus on learning and improvement, not punishment.
- * Regularly review the program to ensure it is fair, ethical and effective.

Advantages of Ethical testing :

- i) Improves employee awareness
- ii) Reduces successful phishing attacks
- iii) strengthens organizational cybersecurity
- iv) creates a security-conscious work culture
- v) helps identify training needs.

Dis-Advantages of unethical testing :

- i) causes stress and emotional harm
- ii) Reduces employee trust
- iii) Lowers workplace morale

iv) creates fear and confusion

v) May lead to legal or ethical issues

Real Life Example :-

→ A company sends a fake email stating that employees must verify their payroll information. Employees who click the link are redirected to a training page explaining the signs of phishing. This improves awareness without causing unnecessary fear or stress.

Conclusion :-

* Social engineering tests are valuable for improving cybersecurity awareness, but they must be conducted ethically. Organizations should obtain proper authorization, respect employee privacy, avoid causing unnecessary emotional distress, and use the results for education rather than punishment. A balanced approach strengthens both security and employee trust.